

POL-SGSI-01: Política de Seguridad en el Desarrollo de Software y APIs

Universidad Nacional del Centro del Perú (UNCP)

SGSI ISO/IEC 27001:2022

Organización: Universidad Nacional del Centro del Perú (UNCP) **Versión:** 1.0 (Enfoque DevSecOps / Shift-Left) **Norma:** ISO/IEC 27001:2022 (Controles A.8.25 - A.8.30) **Alineamiento:** PGTD (Digitalización de procesos académicos)

1. Alcance

Aplica a todos los desarrollos internos (OTI), mantenimiento del ERP ADESA y desarrollos por terceros contratados por la UNCP.

2. Seguridad desde el Diseño (Shift-Left)

- **Análisis de Requisitos:** Todo requerimiento de software debe incluir criterios de seguridad y privacidad desde su definición.
- **Desarrollo Móvil:** Las aplicaciones desarrolladas para uso en dispositivos móviles deben heredar los controles de la **POL-SGSI-05**, asegurando el manejo seguro de datos en entornos no controlados (BYOD).
- **Revisiones de Código:** Se integrarán escaneos estáticos de seguridad (SAST) en los *pipelines* de integración continua (CI/CD).

3. Seguridad en APIs

- Toda API expuesta debe pasar por el **API Gateway (TRV-02)** para control de acceso, rate-limiting y auditoría.
- Uso mandatorio de protocolos seguros (HTTPS, TLS 1.3) y autenticación basada en tokens (OAuth2/OIDC).

4. Gestión de Vulnerabilidades y Parches

- Se prohíbe el uso de bibliotecas de terceros con vulnerabilidades conocidas (CVE).
- Mantenimiento de un **SBOM (Software Bill of Materials)** para rastrear todas las dependencias del software institucional.

5. Entornos de Desarrollo y Pruebas

- Los datos de producción (reales) **nunca** se utilizarán en entornos de desarrollo o pruebas. Se deben aplicar técnicas de enmascaramiento o generación de datos sintéticos.